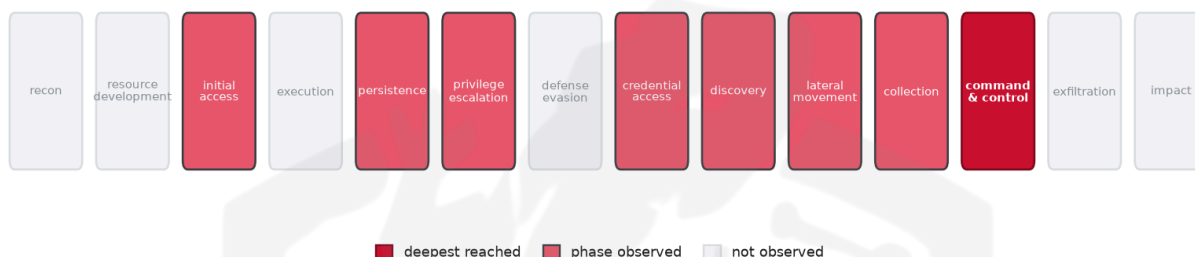


THREAT REPORT: RED HERON EXPLOITS GITEA N-DAY FLAW IN MULTINATIONAL CAMPAIGN

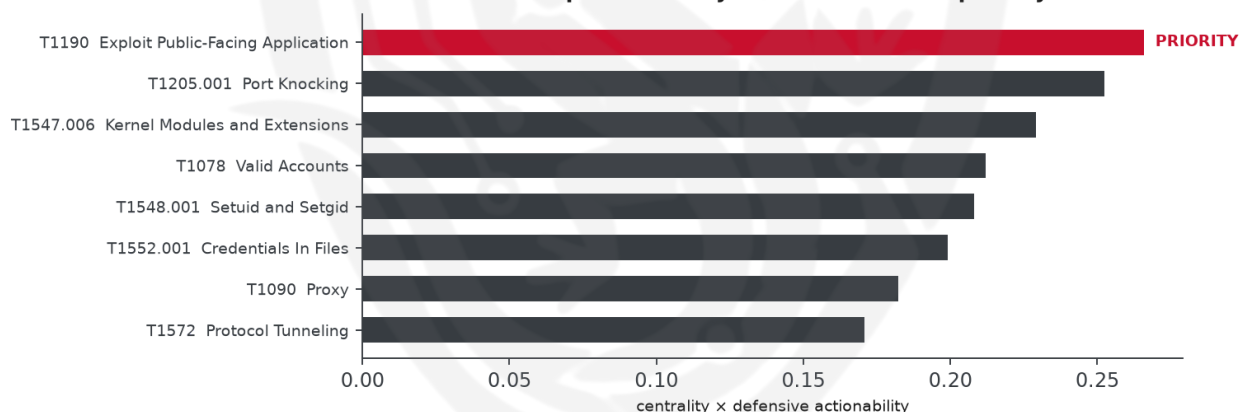
Visual Summary

Kill-Chain Reach — High (deepest phase reached: command-and-control)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

Red Heron is leveraging the newly disclosed CVE-2026-60004 in Gite a to deliver the JITTERLY and SIXZUT Linux rootkits. The campaign spans a broad set of sectors, including defense, government, energy, aerospace, telecommunications, education, finance, technology, and NGOs. Because the targeted victims span critical infrastructure, immediate remediation is essential. Priority should be given to patching the vulnerable public-facing service, applying a virtual patch via a web-application firewall, and restricting management interfaces to VPN-only access while ensuring CVE-2026-60004 is patched on all affected systems.

Threat Overview

The source attributes this activity to Red Heron. The adversary employs the JITTERLY and SIXZUT malware families to exploit the public-facing Gitea vulnerability identified as CVE-2026-60004. Victims are organizations across multiple high-value sectors, though the specific country of the targets is not disclosed.

Attack Chain and Priority Control

The observed attack chain begins with external remote services (T1133) to reach the vulnerable Gitea instance, followed by exploitation of the public-facing application (T1190) using CVE-2026-60004. After initial compromise, the threat actor conducts system owner/user discovery (T1033), system information discovery (T1082), and network configuration discovery (T1016) to map the environment. Credential harvesting is performed via keylogging (T1056.001) and searching for credentials in files (T1552.001). The adversary then establishes persistence through valid accounts (T1078) and creates new accounts (T1136), escalates privileges via exploitation for privilege escalation (T1068) and setuid/setgid (T1548.001), and loads kernel modules (T1547.006). Command-and-control traffic is tunneled (T1572) and proxied (T1090) over web protocols (T1071.001).

Priority technique: T1190 Exploit Public-Facing Application

Priority control (verbatim): Patch the affected public-facing CVE immediately; apply a WAF virtual patch; restrict management interfaces to VPN-only. In parallel, patch CVE-2026-60004 on all affected systems.

Infrastructure and Corroboration

Enrichment data indicate no hosting providers or autonomous system numbers were identified for the malicious infrastructure. Abuse.ch did not corroborate any of the malware families, and AbuseIPDB reported zero indicators with confidence scores of 80 % or higher.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1033 System Owner/User Discovery
- T1056.001 Keylogging
- T1133 External Remote Services
- T1573.001 Symmetric Cryptography
- T1021.004 SSH
- T1082 System Information Discovery
- T1190 Exploit Public-Facing Application
- T1572 Protocol Tunneling
- T1548.001 Setuid and Setgid
- T1016 System Network Configuration Discovery
- T1090 Proxy

- T1083 File and Directory Discovery
- T1552.001 Credentials In Files
- T1205.001 Port Knocking
- T1547.006 Kernel Modules and Extensions
- T1078 Valid Accounts
- T1068 Exploitation for Privilege Escalation
- T1505 Server Software Component
- T1071.001 Web Protocols
- T1136 Create Account

Analytical Scores

- Priority technique (graph chokepoint): T1190 Exploit Public-Facing Application (centrality 0.2658).
- Operational risk: High (score 0.636, reaches command-and-control).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4303; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
FIN13	0.4303
OilRig	0.3285
APT39	0.3236
APT18	0.3236
Ke3chang	0.3212

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Domain	xcyoibfhuufz[.]com

Type	Indicator
Domain	gitea[.]redacted[.]com[.]jar
Domain	s2[.]981666[.]xyz
URL	hxxps://gitea[.]redacted[.]com[.]jar/api/v1/metrics?k=[auth
Hash	3a1e96289832518bff2feeb868bc61a4
Hash	88264a49750b3280e63894fb7445a9c2
Hash	28b132ad55bd310bb5cf3ddb4ace580529ad735204a48cf388830d9039843d8e
Hash	b441f793c87e54cb7e3f7205e25442aa19920d325cb6af41d2afdc8a0b5cf54f

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1190 Exploit Public-Facing Application (initial-access)
- **Observed here:** T1190 Exploit Public-Facing Application was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the execution stage they must still reach.
- **Projected pivot:** T1053 Scheduled Task/Job (execution)
- **Basis:** of the 23+ groups that use Exploit Public-Facing Application, this pairing runs 1.5x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1190 Exploit Public-Facing Application blocked, Red Heron could preserve the same objective by pivoting to T1053 Scheduled Task/Job, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Alert on new scheduled tasks (Event ID 4698); restrict schtasks/at to admins; baseline legitimate task creators.

Also plausible (same tactic): T1059 Command and Scripting Interpreter (n=38, lift 1.2), T1569 System Services (n=8, lift 1.8)

Detection and hardening for the pivot (T1053 Scheduled Task/Job)

- **Telemetry:** Windows Security (Object Access audit); Microsoft-Windows-TaskScheduler/Operational; Sysmon
- **Detect:**
 - Security 4698 (task created), 4702 (updated), 4700/4701 (enabled/disabled), 4699 (deleted)
 - TaskScheduler/Operational 106 (registered), 140 (updated), 141 (deleted)
 - Sysmon 1 for schtasks.exe and at.exe; Sysmon 11 for writes under C:\Windows\System32\Tasks\

- **Harden:**
 - Restrict schtasks/at to administrators; disable the legacy at.exe
 - Baseline the legitimate task creators and alert on anything outside it
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0003 Scheduled Job, DS0009 Process, DS0022 File

